Nimbus Orbit Technologies Pvt. Ltd.

IT and Information Security Policy | Access, Devices, Incident Response and Support

Policy owner: Chief Information Security Officer (Imran Sheikh) | Version 3.4 | Effective: 1 July 2026 | Classification: Internal | Security desk: security@nimbusorbit.example.com

1. Purpose

This document defines how Nimbus Orbit employees, contractors, and vendors must protect company, customer, and learner data, and describes how IT services are delivered and supported. It supports the company's ISO/IEC 27001 and SOC 2 Type II certifications, both renewed in September 2026.

2. Data Classification

Level	Examples	Handling rules
Public	Marketing pages, published blogs, price list	No restrictions
Internal	Policies, org charts, internal wikis	Share only within the company
Confidential	Customer contracts, source code, financials, roadmaps	Access on need-to-know; encrypted at rest and in transit; no personal cloud storage
Restricted	Learner personal data, authentication secrets, encryption keys, payment data	Strict access approval by data owner; access logged and reviewed monthly; never stored on laptops

3. Identity and Access Management

- All employees sign in through OrbitID single sign-on with multi-factor authentication (MFA) mandatory for every account.
- Approved MFA methods are the Nimbus Authenticator app or a hardware security key. SMS codes are not allowed for privileged accounts.
- Access follows least privilege. New access requests are raised in the IT service desk and approved by the manager and data owner.
- Quarterly access reviews are performed by system owners; unused accounts are disabled after 45 days of inactivity.
- On resignation, all access is revoked within 1 hour of the employee's last working day ending.
- Production access is granted just-in-time for a maximum of 4 hours and requires a linked change or incident ticket.

4. Password Standards

Requirement	Standard
Minimum length	14 characters (passphrases recommended)
Rotation	Not required unless compromise is suspected; breached passwords must be changed immediately

Requirement	Standard
Reuse	Last 12 passwords cannot be reused
Password manager	Employees must use the company-provided password manager (Vaultline)
Lockout	Account locks for 15 minutes after 5 failed attempts
Service accounts	Secrets stored in the secrets vault and rotated every 90 days

5. Devices and Endpoint Security

- Company laptops are standard Apple MacBook Pro or Lenovo ThinkPad models, refreshed every 4 years.
- All devices must have full-disk encryption, endpoint detection and response (EDR) software, and automatic OS updates enabled.
- Screens auto-lock after 5 minutes of inactivity.
- Personal devices (BYOD) may access email and chat only through the managed mobile app and must not store company files locally.
- Removable USB storage is blocked by default; exceptions require approval from the CISO.
- Lost or stolen devices must be reported to the security desk within 2 hours so the device can be remotely wiped.

6. Network and Remote Access

Employees working outside the office must connect to the company VPN (OrbitSecure) before accessing internal systems. Split tunnelling is disabled. Public Wi-Fi may be used only with the VPN active. Office guest Wi-Fi is isolated from the corporate network. Production environments are reachable only from a bastion host with session recording.

7. Software Development Security

- All code is stored in the company's Git platform; direct commits to the main branch are blocked.
- Every pull request requires at least one peer approval and passing automated tests.
- Static analysis, dependency scanning, and secret scanning run on every build.
- Critical vulnerabilities must be fixed within 7 days, high within 30 days, and medium within 90 days.
- Third-party penetration tests are performed twice a year by an independent firm.
- Customer data must never be used in development or testing environments unless masked.

8. Backup and Disaster Recovery

System	Backup frequency	Retention	RTO	RPO
Production databases	Continuous replication plus daily snapshot	35 days	2 hours	15 minutes
File storage (customer uploads)	Daily incremental	90 days	4 hours	24 hours

System	Backup frequency	Retention	RTO	RPO
Source code repositories	Every 6 hours	1 year	4 hours	6 hours
Internal tools (wiki, ticketing)	Daily	30 days	8 hours	24 hours

Primary hosting is in the Mumbai cloud region, with a disaster recovery site in Hyderabad. Full failover drills are run every 6 months; the most recent drill took place on 12 September 2026 and met its 2-hour recovery target.

9. Incident Response

Any employee who suspects a security incident, such as phishing, malware, lost devices, or unauthorized access, must report it immediately to security@nimbusorbit.example.com or the 24x7 security hotline +91-80-5550-1911. Do not attempt to investigate on your own.

Severity	Description	Response time	Notifications
Critical (P1)	Confirmed data breach, ransomware, or full outage of a production system	15 minutes	CISO, CEO, legal; customers notified within 72 hours where personal data is affected
High (P2)	Suspected breach or compromise of a privileged account	1 hour	CISO and engineering head
Medium (P3)	Malware on a single device, policy violation	4 hours	Security team
Low (P4)	Phishing email reported, no click-through	1 business day	Security team

The incident response lifecycle follows five phases: detection, containment, eradication, recovery, and a post-incident review. Blameless post-incident reviews are held within 5 business days for P1 and P2 incidents.

10. IT Service Desk

The IT service desk handles equipment, accounts, software, and access requests. It is available at itsupport@nimbusorbit.example.com, on chat in the #it-help channel, and on extension 4000. Hours are 8:00 AM to 8:00 PM IST on working days, with on-call coverage for urgent issues.

Request type	Target turnaround
Password reset or MFA re-enrolment	30 minutes
New laptop for a new joiner	Ready on day 1 if requested 5 working days in advance
Software installation (approved list)	1 working day
Software not on the approved list	5 working days, subject to security review
Access to a Confidential system	2 working days
Access to a Restricted system	3 working days with data owner approval

11. Acceptable Use

- Company systems are for business use; limited personal use is permitted if it does not affect work or security.
- Do not install unapproved software, browser extensions, or AI tools that upload company data to external services.
- Generative AI tools may be used only from the approved list, and never with Confidential or Restricted data.
- Do not share credentials, tailgate into secure areas, or leave visitors unattended.
- Email, chat, and files on company systems may be monitored for security and legal compliance.

12. Vendor and Third-Party Security

Every vendor that handles Confidential or Restricted data must complete a security assessment before contract signature and again every 12 months. Vendors must sign a data processing agreement and notify Nimbus Orbit of any breach within 48 hours. The procurement team keeps a vendor register owned by Rohan Deshpande's finance team and reviewed by the CISO.

13. Privacy and Data Retention

Data type	Retention period
Learner account data	Duration of customer contract plus 90 days
Application logs	12 months
Audit and access logs	24 months
Employee records	7 years after separation
Financial records	8 years
Customer support tickets	3 years

Data subject requests (access, correction, deletion) are handled by the Data Protection Officer, Lakshmi Venkatesh, at dpo@nimbusorbit.example.com and must be completed within 30 days.

14. Security Awareness Training

All employees complete security awareness training within 30 days of joining and annually thereafter. The security team runs simulated phishing campaigns every month. Employees who fail three consecutive simulations must complete additional training. Developers complete secure coding training every year.

15. Frequently Asked Questions

Q: What is the minimum password length?

A: 14 characters.

Q: Whom do I contact if my laptop is stolen?

A: Report to the security desk within 2 hours at security@nimbusorbit.example.com or +91-80-5550-1911.

Q: How quickly must critical vulnerabilities be fixed?

A: Within 7 days.

Q: What is the RTO for production databases?

A: 2 hours, with an RPO of 15 minutes.

Q: Which VPN do employees use?

A: OrbitSecure, required whenever working outside the office.

Q: Can I use public AI chatbots with customer data?

A: No. Only approved AI tools may be used, and never with Confidential or Restricted data.